AUTHENTICATED ENCRYPTION

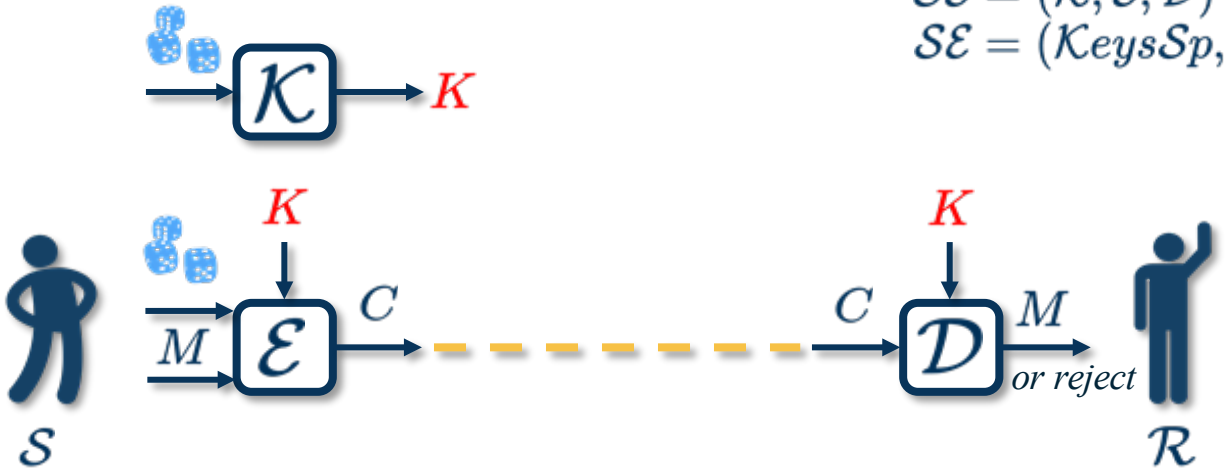
Can We Get It All?

- We know how to achieve data privacy (IND-CPA security) and data authenticity/integrity (UF-CMA security) separately.
- Can we achieve both goals at the same time (can we send messages securely, s.t. a receiver is assured of their authenticity/integrity)?
- Can we use the existing primitives: encryption schemes and MACs?

Authenticated Symmetric Encryption Syntax

- A scheme $\mathcal{SE}$ is specified by 3 algorithms $\mathcal{K}$ (or $\mathcal{KeySp}$), $\mathcal{E}$, $\mathcal{D}$ and the message space $\mathcal{MsgSp}$.

$\mathcal{SE} = (\mathcal{K}, \mathcal{E}, \mathcal{D})$ or
$\mathcal{SE} = (\mathcal{KeysSp}, \mathcal{E}, \mathcal{D})$



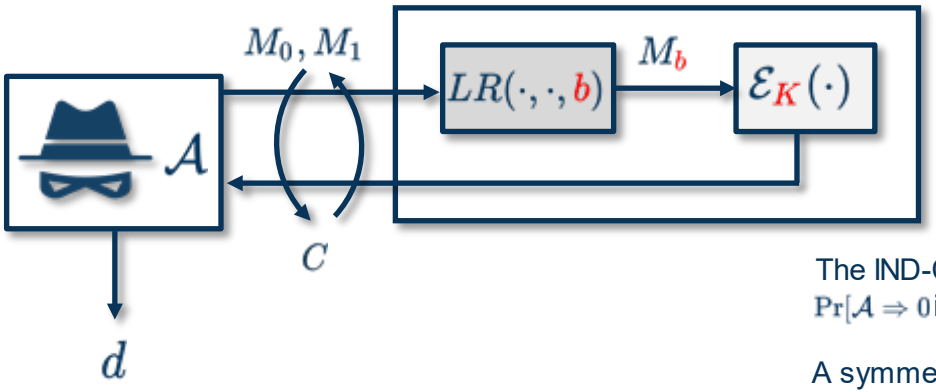
It is required that for every $M \in \mathcal{MsgSp}$ and every $K \in \mathcal{KeySp}$ (or output by $\mathcal{K}$), $\mathcal{D}(K, \mathcal{E}(K, M)) = M$.

Indistinguishability under Chosen-Plaintext Attacks

Fix $\mathcal{SE} = (\mathcal{KeySp}, \mathcal{E}, \mathcal{D}), K \xleftarrow{\$} \mathcal{KeySp}$

For an adversary $\mathcal{A}$ and a bit b (either 0 or 1) consider an experiment ind-cpa-b, i.e., consider two experiments, ind-cpa-0 (“left”) and ind-cpa-1 (“right”).

In each experiment, $\mathcal{A}$ is given access to the “left-right” encryption oracle that takes two messages and returns encryption of M_b under K



The IND-CPA advantage of $\mathcal{A}$ (denoted as $\mathrm{Adv}^{\text{ind-cpa}}(\mathcal{A})$) is $\Pr[\mathcal{A} \Rightarrow 0$ in ind-cpa-0 exp. $] - \Pr[\mathcal{A} \Rightarrow 0$ in ind-cpa-1 exp. $]$

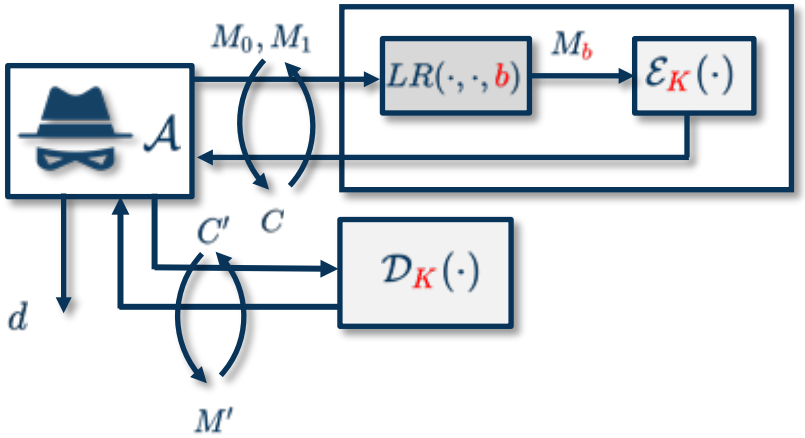
A symmetric encryption scheme $\mathcal{SE}$ is indistinguishable under chosen-plaintext attacks (IND-CPA secure) if for any adversary $\mathcal{A}$ with “reasonable” resources its ind-cpa advantage is “small” (close to 0).

Indistinguishability under Chosen-Ciphertext Attacks

Fix $\mathcal{SE} = (\mathcal{KeySp}, \mathcal{E}, \mathcal{D}), K \xleftarrow{\$} \mathcal{KeySp}$

For an adversary $\mathcal{A}$ and a bit b (either 0 or 1) consider an experiment ind-cca-b, i.e., consider two experiments, ind-cca-0 (“left”) and ind-cca-1 (“right”).

In each experiment, $\mathcal{A}$ is given access to the “left-right” encryption oracle that takes two messages and returns encryption of M_b under K, and decryption oracle. $\mathcal{A}$ cannot query the decryption oracle on ciphertexts from the “left-right” encryption oracle.



The IND-CCA advantage of $\mathcal{A}$ (denoted as $\mathrm{Adv}^{\text{ind-cca}}(\mathcal{A})$) is $\Pr[\mathcal{A} \Rightarrow 0 \text{ in ind-cca-0 exp.}] - \Pr[\mathcal{A} \Rightarrow 0 \text{ in ind-cca-1 exp.}]$

A symmetric encryption scheme $\mathcal{SE}$ is indistinguishable under $\mathcal{A}$ chosen-ciphertext attacks (IND-CCA secure) if for any adversary with “reasonable” resources its ind-cca advantage is “small” (close to 0).

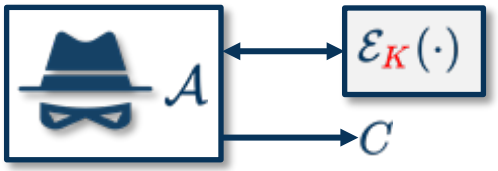
Extra Goal

- In addition to data privacy (IND-CCA) we want to achieve authenticity and integrity
- We need to define an additional security notion for encryption, similar to UF-CMA for MACs
  - Same intuition: the adversary should not be able to produce a forgery, which now is a new valid ciphertext

Integrity of Ciphertexts (INT-CTXT)

Fix $\mathcal{SE} = (\mathcal{KeySp}, \mathcal{E}, \mathcal{D}), K \xleftarrow{\$} \mathcal{KeySp}$

For an adversary $\mathcal{A}$ consider an experiment called INT-CTXT



The INT-CTXT advantage of $\mathcal{A}$, $\mathbf{Adv}^{\text{int-ctxt}}_{\mathcal{SE}}(\mathcal{A})$
is $\Pr[\mathcal{A}$ outputs C s.t. $\mathcal{D}_K(C)$ does not reject and input C was never a response of $\mathcal{E}_K(\cdot)]$

INT-CTXT security is defined the usual way.

What We Need

- We want to have schemes that are
  - IND-CCA and INT-CTXT
- **Theorem:** If a symmetric encryption scheme is IND-CPA and INT-CTXT, then it is also IND-CCA
- Hence, it's enough to find schemes that are IND-CPA and INT-CTXT
- CBC$ is IND-CPA. Is it INT-CTXT?

Combining Encryption and MACs

- It makes sense to build secure authenticated encryption from basic encryption and MAC
- We will call the resulting scheme a composite scheme

Generic Composite Schemes

- Fix a symmetric encryption scheme and a message authentication code
- There are several ways to use them together
  1. Encrypt-and-MAC (used in SSH)
  2. MAC-then-Encrypt (used in SSL/TLS)
  3. Encrypt-then-MAC (used in IPSec)
- If the components are secure (encryption is IND-CPA and MAC is UF-CMA or PRF), are the composite authenticated encryption schemes secure (IND-CPA and INT-CTXT)?

Composite Schemes

- Build an authenticated encryption scheme $\mathcal{AE} = (\mathcal{K}, \mathcal{E}, \mathcal{D})$ by combining
  - a given IND-CPA symmetric encryption scheme $\mathcal{SE} = (\mathcal{K}', \mathcal{E}', \mathcal{D}')$
  - a given PRF $F : \{0,1\}^k \times \{0,1\}^* \to \{0,1\}^n$

- A key $K = K_e \| K_m$ for $\mathcal{AE}$ always consists of a key K_e for $\mathcal{SE}$ and a key K_m for F:

Algorithm $\mathcal{K}$

$K_e \xleftarrow{\$} \mathcal{K}'$; $K_m \xleftarrow{\$} \{0,1\}^k$

Return $K_e \| K_m$

Encrypt-and-MAC

- $\mathcal{AE} = (\mathcal{K}, \mathcal{E}, \mathcal{D})$ is defined by

Algorithm $\mathcal{E}_{K_e \| K_m}(M)$
$C' \xleftarrow{\$} \mathcal{E}'_{K_e}(M)$
$T \leftarrow F_{K_m}(M)$
Return $C' \| T$

Algorithm $\mathcal{D}_{K_e \| K_m}(C' \| T)$
$M \leftarrow \mathcal{D}'_{K_e}(C')$
If $(T = F_{K_m}(M))$ then return M
Else return $\perp$

Security	Achieved?
IND-CPA	
INT-CTXT	

Encrypt-and-MAC

- IND-CPA security is **not** guaranteed. Why?

MAC-then-Encrypt

- $\mathcal{AE} = (\mathcal{K}, \mathcal{E}, \mathcal{D})$ is defined by

Algorithm $\mathcal{E}_{K_e \| K_m}(M)$
$T \leftarrow F_{K_m}(M)$
$C \xleftarrow{\$} \mathcal{E}'_{K_e}(M \| T)$
Return C

Algorithm $\mathcal{D}_{K_e \| K_m}(C)$
$M \| T \leftarrow \mathcal{D}'_{K_e}(C')$
If $(T = F_{K_m}(M))$ then return M
Else return $\perp$

Security	Achieved?
IND-CPA	
INT-CTXT	

MAC-then-Encrypt

- IND-CPA security is guaranteed. Why?
- INT-CTXT security is **not** guaranteed. Why?

Encrypt-then-MAC

- $\mathcal{AE} = (\mathcal{K}, \mathcal{E}, \mathcal{D})$ is defined by

Algorithm $\mathcal{E}_{K_e \| K_m}(M)$
$C' \xleftarrow{\$} \mathcal{E}'_{K_e}(M)$
$T \leftarrow F_{K_m}(C')$
Return $C' \| T$

Algorithm $\mathcal{D}_{K_e \| K_m}(C' \| T)$
$M \leftarrow \mathcal{D}'_{K_e}(C')$
If $(T = F_{K_m}(C'))$ then return M
Else return $\perp$

Security	Achieved?
IND-CPA	
INT-CTXT	

Encrypt-then-MAC

- IND-CPA security is guaranteed.
- INT-CTXT security is guaranteed.
- **Theorem:** EtM is IND-CPA and INT-CTXT if the base encryption is IND-CPA and F is PRF.
- Candidate choices: AES-CBC$ and HMAC-SHA-3.

One Key Instead of Two?

- We have used separate keys K_e, K_m for the encryption and message authentication. However, these can be derived from a single key K via a PRG as follows:
  - $K_e = F_K(0)$ and $K_m = F_K(1)$ where F is a PRF such as a secure blockcipher.

- Trying to directly use the same key for the encryption and message authentication is error-prone, but works if done correctly.

Generic Composition is Practice

Protocol with AE	Based on	In general is	In this case is
SSH+RFC4344	E&M	insecure	secure*
SSL	MtE	insecure	secure*
IPSec	EtM	secure	secure*
WinZip	EtM	secure	insecure

How can this be?

- Encodings
- Specific base schemes
- Disparity between usage and security model

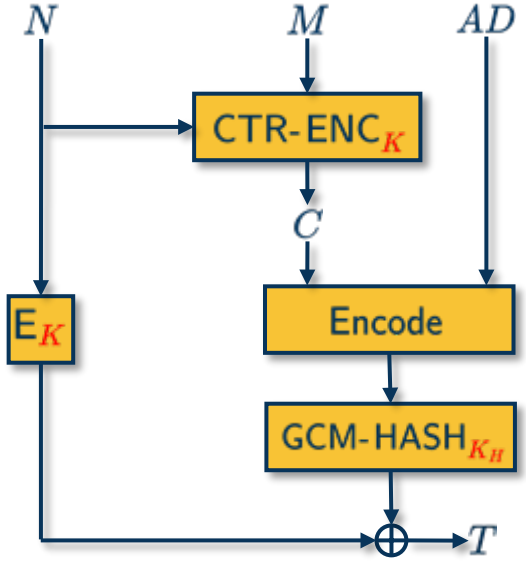
Dedicated AE

- It’s possible to construct authenticated encryption without using a generic composition
- Example: OCB (OCB, OCB2, OCB3), a one-pass, parallelizable scheme
  - OCB2 was broken

AEAD

- Authenticated encryption is commonly used as AEAD-authenticated encryption with associated data
  - Associated Data (AD) is authenticated but not encrypted
  - Schemes are nonce-based (and deterministic)

Example: GCM



- GCM-HASH is a polynomial-based hash
- K_H is derived from K via E
- Can be used as a MAC
- Standardized: NIST SP 800-38D

CAESAR: Competition for Authenticated Encryption

- http://competitions.cr.yp.to/caesar.html